Monthly Intelligence Dispatch

August 2019

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specialises in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB analysts detected attacks by the Silence group in more than 30 countries in Europe, Asia, and post-Soviet states. Between June 2016 and June 2019, the group stole at least US$**4.2 million**, the new report on Silence says.
- APT28 is increasingly using IoT (Internet of things) devices in their cyberespionage attacks.
- Group-IB's Threat Intelligence experts discovered a major leak affecting Sephora, a chain of personal care and beauty stores.
- In late August 2019, the Cobalt group launched large-scale attacks worldwide.
- To attack bank customers threat actors are now using TeamViewer, a legitimate remote access program.
- Group-IB discovered Lotsy, a group of traffers that abuse dozens of European brands, such as **Alltalia**, **Conad**, **Carrefour** and **Target**, with the aim of monetizing ad traffic.
- A malicious program for POS terminals called MagicPos is offered for purchase on hacker forums, it was observed.
- A member of TipTop, a hacking group that stole money from bank cards using the **Hqwar** malware, has been convicted.

Silence

In August 2019, Group-IB published a technical report called **Silence 2.0: going global**, which describes the crimes of the Russian-speaking hackers from the Silence group. It has been confirmed that the group stole at least US$**4.2million** between June 2016 and June 2019. Group-IB experts have been continuously monitoring Silence's activities since 2016. Over this period, Group-IB Threat Intelligence, a cyberthreat monitoring, analysis and forecasting system, has recorded **16** new Silence campaigns targeting banks worldwide. According to Group-IB's data, the geography of Silence's attacks in 2019 has been the largest in the group's history. The hackers infected workstations in over 30 countries in Asia, Europe, and post-Soviet states. In July, Silence's victims were banks in Chile, Bulgaria, and Gana; in June, the hackers launched a series of attacks on Russian banks; in May there were two successful attacks: one in Kyrgyzstan and the other at Dutch-Bangla Bank, a Bangladeshi bank; in February a Russian bank called IT Bank fell victim; and in January a bank in India was hacked. It has been confirmed that the damage Silence has caused since the previous report was released has increased five fold and amounts to at least US$4.2 million. Having started with targets in Russia, the attackers gradually shifted their focus to post-Soviet states before going global. Among their tactical changes is a two-step approach to the attack preparation stage. First, the hackers send out "recon" emails with no payload to a huge recipient database (up to 85,000 users), which helps them create an up-to-date list of active targets, expand the geography of their attacks, and identify the cybersecurity solutions a particular bank uses. The recon mail-outs result in the creation of a "target" list of email addresses that can be used for further attacks with malicious attachments. The report describes three such campaigns in Russia and other post-Soviet countries, Asia, and Europe. The hackers sent out a total of more than 170,000 emails to update their list of future target email addresses.

APT28	**Microsoft Threat Intelligence Center** experts warned about changes in the style of the notorious Russian-speaking group APT28 (also known as Fancy Bear, Pawn Storm, Strontium, Sofacy, Sednit, and Tsar Team). The hackers have been increasingly compromising IoT devices (VoIP phones, printers, etc.) to penetrate networks and then switch to more important targets. APT28 started applying this tactic in April 2019. The researchers observed at least three such cases. In two of them, the passwords for the hacked IoT devices were deployed without changing the default manufacturer's password and in the third case the device did not have the latest security update. The compromised devices are said to have been used by the hackers as points of ingress in the target networks, that is, once they established access to the network, the hackers searched for other vulnerabilities in the system and ways to develop their attack further. The researchers say that after gaining access to the IoT devices, the threat actors launched *tcpdump* to sniff network traffic and enumerated administrative groups.
Hexane	Specialists at **Dragos** discovered a previously unknown threat actor they called Hexane. The group targets oil and gas companies in the Middle East, mainly those in Kuwait. As a gateway, Hexane uses telecommunications providers in the greater Middle East, Central Asia, and Africa. The experts note that the group has been around since at least mid-2018 but has recently become particularly active, likely due to increased tensions in the Middle East. For the initial infection the hackers use malicious documents. It is believed that the compromised telecommunications companies are the first step in future man-in-the-middle attacks.

Major events: espionage, sabotage, leaks

Machete	Experts at ESET reported about attacks by the cyber-espionage group Machete targeted at government institutions in Latin America. The hackers' goal is cyberespionage with a particular focus on files that describe navigation routes and positioning using military grids. The group has been active and known to specialists since at least 2010. The hackers used to attack targets worldwide, but in 2019 they concentrated their efforts on Venezuela. Between March and May 2019, ESET experts discovered more than 50 infected computers that actively communicated with the C&C server. More than 75% of the compromised computers were part of Venezuelan government organizations, including the military forces, education, police, and foreign affairs sectors.
Cloud Atlas	Kaspersky Lab reported that the Cloud Atlas (Inception) group, which they have been tracking since 2014, expanded its arsenal and now uses new polymorphic malware. Cloud Atlas mainly engages in cyberespionage targeting industries and government entities. Since early 2019, the group's phishing campaigns have mostly been focused on Russia, Central Asia, and some regions in Ukraine. The researchers say the group is still relying on its effective existing tactics and malware. The hackers still use phishing emails to target high-profile victims. These emails are crafted with Office documents that use remote malicious templates hosted on remote servers.

Cobalt

On 20 and 23 August **2019**, Cobalt launched large-scale attacks on banks worldwide. Both their first email with the subject "Thank you for requesting an account" and the second one with the subject "To complete the account creation" contain two links to .img files that carry malicious files for downloading **CobInt Stager**. A few days before the attack, on 15 August 2019, CobInt Stager samples were uploaded to VirusTotal from Moldavia through the web interface. The threat actor started the attack by sending a document with a macro, which once enabled downloads CobInt stager from the compromised server of a legitimate website ollyesse[.]com used for hosting the malware.

It is worth mentioning that Cobalt remained the most aggressive and active threat actor throughout 2018. According to Europol, as at the beginning of 2018, the group had stolen about one billion euros from 100 banks in 40 countries. Group-IB's forensics specialists were among the first to study Cobalt's attacks on Russian and international banks. The group's phishing emails reached as far as banks in Australia and Japan. Despite the arrest of one of Cobalt's leaders in spring 2018 in the Spanish city of Alicante, attacks on financial organisations continue.

NCR

As early as April 2019, ATM malware was detected in African countries. Group-IB specialists conducted an analysis and established that the malware was designed for withdrawing banknotes from NCR ATMs. In certain situations it can function on any other hardware that supports the XFS standard. The analysis revealed that the malware is designed to control ATM dispensers through the PIN pad. If the user enters the PIN **01973**, the malware lets them interact with the dispenser directly. If the card with the number **6048631261291531** is inserted, the dispenser will issue all banknotes it has. To interact with the malware the operator needs to enter commands using the PIN pad. To avoid other instances of the program being launched, the malware creates the mutext BitcoinAPP. The attackers used the file cmd.dll to bypass whitelists. cmd.dll is an equivalent of the system utility cmd.exe, built by ReactOS developers. At the time of the research (April 2019) the malware file had not been uploaded to VirusTotal. It was uploaded in August 2019 from Kazakhstan through the web interface.

TeamViewer

In August 2019, Group-IB reported about a new wave of theft activities targeting online banking users. The new scheme involves TeamViewer, a legitimate remote access program that allows a third party to connect to the user's smartphone. Over the last six months, Group-IB's Secure Bank system has been recording an average of 1,000 attempts per month to withdraw funds from personal bank accounts using the new fraud scheme. With minor differences, the fraud scheme involving TeamViwer is as follows: posing as a bank employee the threat actor calls a customer and tells them that there had been an attempt to hack their user account or withdraw money from their bank account. The fraudster says that the bank's security services need the customer's help in solving a technical problem to tackle the theft attempt. For this purpose, the customer is asked to urgently install a remote access program on their smartphone so that the security team has access to it and ensures the customer is safe. Once such a program is installed, the fraudsters can access the user's online banking app and withdraw money from their account. According to Group-IB Secure Bank, fraud involving mobile apps and TeamViewer peaked in spring 2019, with Group-IB receiving large numbers of requests from banks in April and May. In one bank only, Group-IB prevented damage from the remote access scheme amounting to US$250,000 in two months. The average damage to a major bank from this kind of fraud can reach US$93,000 to 156,000.

Major events: vulnerabilities

CTF in Windows OS

On 13 August 2019, Tavis Ormandy, a researcher at Google's Project Zero, published information about a vulnerability in the CTF protocol in Windows OS. CTF is used in all Windows versions starting from Windows XP and is part of the Windows Text Services Framework (TSF), which is a system for displaying text in Windows and applications. The researcher discovered that the communication between the CTF client and its server did not require authentication and had no other security mechanisms in place. As a result, anyone could interfere in the communication between the client and the server. This means that a threat actor can connect to another user's active session and take over any application, or wait for an administrator to log in and compromise their session. The actor will be able to send commands to applications acting as a server. Tavis Ormandy posted a video showing how the vulnerability can be exploited and released a tool on Github that will help researchers check the protocol for other security problems.

Emporium Rodrigues

On 11 August 2019, TMT, an underground forum user who offers a service for gaining access to corporate networks, announced that they had gained access to **Emporium Rodrigues**, a Brazilian supermarket chain. In addition, the user has access to all POS terminals of the chain. This poses a risk of the company being infected with a POS Trojan that could compromise bank cards. Group-IB specialists contacted the threat actor and obtained the full list of compromised companies. The threat actor has been actively working on corporate networks since November 2018 (they had earlier engaged in carding), while looking for people to form a team and improving his skills in this area.

Sephora

Group-IB's Threat Intelligence experts discovered a data leak affecting the customers of Sephora, a chain of personal care and beauty stores (part of Louis Vuitton Moët Hennessy (LVMH) conglomerate since 1997). In July 2019, the researchers discovered two databases with information about Sephora customers on the Darknet. The first dump was published on two hacker forums on 6 and 17 July 2019. It contains **500,000** entries, including user names and hashed passwords for Sephora.co.id (Indonesia) and Sephora.co.th (Thailand). The author of the post says the information is dated February 2019. The second dump was discovered on an underground forum on 28 July 2019 and contains **3.2 million** entries, which the researchers believe were leaked in March 2019. An analysis of the leaked data revealed that the information includes logins, hashed passwords, registration dates, last active dates, IP registration, last IP, sex, first name, last name, ethnicity, eye colour, skin colour, skin type, hair colour, hair problems, etc. This set of data is sold at US$1,900. Even though the leaks do not contain any payment information or decrypted passwords, they can be used in spear-phishing attacks with social engineering techniques.

Card Present

Gemini Advisory experts discovered that payment card details of more than one million South Korean users are sold on the Darknet. The researchers say the information about 890,000 and 230,000 payment cards was put up for sale on a hacker forum in July and June 2019. The fact that the dumps only contained CP data (Card Present), rules out that the data was leaked through the use of software skimmers (MageCart scripts) installed on hacked online stores. The experts believe that the threat actors may have collected information about one million cards by employing several methods: using malware installed on Point-of-Sale (POS) systems in stores or restaurants; hacking a bank, payment system of POS company; or using skimmers installed on ATMs or POS terminals. However, the third method is unlikely to have been used, since South Korea has widely adopted EMV cards.

Lotsy

Group-IB detected Lotsy, a group of traffers that abuse dozens of European brands, such as **Alltalia**, **Conad**, **Carrefour** and **Target**, with the aim of monetizing the contents of ad traffic. Group-IB experts detected a total of **114** interlinked fake web resources involved in the Lotsy fraud scheme.

Lotsy attracts customers to web resources disguised as the websites of famous brands, including supermarkets and retail chains, and asks users to fill in questionnaires in exchange for gifts and bonuses. Once the user completes such a test or questionnaire, which copies the design of the legitimate resource of a given brand and uses a similar-looking domain, they are prompted to share the link with their friends on Facebook or WhatsApp to receive their gift.

For the purposes of generating traffic, the user is then redirected to third-party toxic web resources, which instead of the promised gifts offered paid subscriptions and services or suggested installing browser extensions. The Lotsy scheme comprised over 110 fake websites, with about 28 of them being active at the moment.

According to the data Group-IB has, the Lotsy group started their activities in the summer of 2017. In addition to the scheme with lotteries and questionnaires, the fraudsters' style can also be identified by the design of their fake websites. Over the last two years, over 100 brands have been targeted by Lotsy. Such schemes with redirections to other resources pose risks both for ordinary users (who may be tricked into subscribing to unnecessary paid services, or – in the worst case scenario – be redirected to a website with malware) and for brands, who may experience serious reputational damage.

Major events: malware

Buer loader

On 15 August, a user named memeos made a post about selling a new loader called **Buer loader** on exploit.in, an underground forum. Once the victim is infected, the Trojan establishes persistence in the system and can download and execute the payload in the form of DLL files or Win32 EXE, as well as add the loaded executable to startup. The Trojan works with User privileges. Its author says the Trojan works on all operating systems (x86/x64) from Windows 7 to Windows 10 and also supports their server versions. It is worth mentioning that the malware has modular architecture, but the author says the modules are in their development stage. The price for the malware is $350.

The loader has been developed since late 2018 – early 2019, judging by the fact that some of the bots first appeared at that time.

CVE-2019-1069

On 18 August 2019, a threat actor named luxor2008 started selling an LPE exploit for CVE-2019-1069 on an underground forum. Microsoft patched this vulnerability in June 2019. CVE-2019-1069 is an EoP (escalation of privileges) vulnerability in Windows Task Scheduler. All Windows 10 versions as well as Windows Server 2016 and later are vulnerable. The exploit is sold at US$5,000. It is worth mentioning that luxor2008 is well known in the underground community and has already sold exploits before (for CVE-2018-8453 and CVE-2016-7255).

SHERIFF

Since early 2019, a threat actor named SHERIFF has been selling access to databases and website admin panels on exploit.in, an underground forum. Since the start of the year, SHERIFF has put up for sale about **50** different databases and access opportunities. The threat actor has been active since late 2016 and has always used the same nickname. The actor initially engaged in carding in 2017-18, before starting selling accounts they obtained through brute force attacks. Since late 2018, they have been working with specialised software for penetration testing: SIB service, X-MapAdmin and OWASP ZAP, which they have used for searching for vulnerabilities on various resources.

Major events: malware

MagicPOS

Two copies of the source code of MagicPOS, a malicious program for POS terminals, were put up for sale on **Exploit**, an underground forum. The author of the post is a user named cartonash. Together with the source code, the seller provides a script for creating card shops. It was found out, however, that cartonash is not the developer of the malware. They bought the malicious program for more than $30,000. Having worked with the program for one month they managed to acquire $23,000. The reason for selling it is that the threat actor does not have enough time. By selling several copies of the malware the seller is trying to recover the money they spent. In addition, the seller said that together with the malware they are prepared to provide a script for producing statistics on collected dumps. The threat actor offered selling two copies of the malware: one with an account on Omerta, a forum, for $9,000 and the other without an account for $6,500. During the discussions, the seller agreed to lower the price to $5,000. The threat actor says they have already sold one copy.

Titan

On 17 August 2019, a user nicknamed opoboc posted a link on exploit,in, an underground forum, to their Github account, where they claim to have the source code of Titan, a banking bot they developed themselves. According to the description on Github, the bot has the following capabilities: keylogger, grabber, backconnect, remote access to the infected machine, and form grabber.

Arrests and sentences

TipTop

A member of the TipTop hacking group, which stole money from bank cards using the **Hqwar** malware, was convicted in Russia. The member was arrested with the assistance of Group-IB. The group distributed their malware by disguising it as popular mobile apps. Downloading such an app prompted the download of the actual malware, which gave the hackers access to the mobile banking services the victim used. Once the user tried to download one of the malicious apps, the **Hqwar** Android banking Trojan (also known as Agent.BID) was installed on their device. The group tried other tools and money withdrawal schemes too, which made it difficult to attribute a particular attack to them. All mobile Trojans used by the hackers could intercept and read SMS messages, record phone calls and send USSD requests, but their main goal was to steal bank card details either by using phishing windows that copied legitimate application windows or employing web fakes designed to trick users into entering their logins and passwords for popular online banking services. The servers the group used for infecting their victims with malware and managing botnets were at different times located in Germany, the US, and Ukraine.

Retadup

The French National Gendarmeri together with Avast specialists reported about their victory over a major threat called Retadup. The experts took control over the infrastructure of the operators of the malware and made it remove itself from **850,000** infected Windows machines. The Retadup worm has been known to the cybersecurity community since 2017. Threat actors have used it to distribute infostealers, ransomware, and cryptocurrency miners. In the recent months, the malware has mostly been used to install Monero miners on devices in Latin America.

Forecasts and warnings

- New test mail-outs by Silence can be expected. First, the group sends “recon” emails with no payload to a huge recipient database (up to 85,000 users), which helps the hackers create an up-to-date list of active targets, expand the geography of their attacks, and identify the cybersecurity solutions a particular bank uses. The recon mail-outs result in the creation of a “target” list of email addresses, that can be used for further attacks with malicious attachments.
- Even though the leak of Sephora customers’ data does not contain any payment information or decrypted passwords, Group-IB analysts warn that the information can still be used for spear-phishing attacks with social engineering techniques.
- By exploiting vulnerabilities in the CTF protocol in Windows OS, a threat actor can connect to another user's active session and take over any application, or wait for an administrator to log in and compromise their session. As a result, the actor will be able to send commands to applications acting as a server.
- The Brazilian supermarket chain Emporium Rodrigues faced the risk of being compromised: the threat actor has access to all POS terminals of the chain, which means that there is a real threat of the company being infected with a POS Trojan that could compromise bank card details.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organisation.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com